Guía P2 — Planeación, riesgos y controles

Nov 3, 2026 · @Anthony

Lo que te toca

Te toca lo que pasaba antes del ataque: planear la auditoría, convertir las doce alertas en una matriz de riesgos y evaluar los controles de accesos, cambios y aplicaciones. En el equipo coordinas: llevas el registro de supuestos y armas el informe final.

Tu parte pesa en planeación (1.0), riesgos (2.0) y controles ITGC, aplicaciones y base de datos (2.0), es decir, 5 de los 15 puntos. Los controles de base de datos los compartes con P1, que te pasa la evidencia de sus consultas.

En concreto: ficha de auditoría y carta de encargo, diagramas de arquitectura y de proceso, inventario de activos, tabla de las doce alertas, escala y matriz de riesgos con Top 5, matriz RACI de RedNova, programa de pruebas, pruebas de ITGC y de la aplicación móvil, dos borradores de hallazgos e integración del informe con bibliografía y declaración de IA.

Cómo nos repartimos el proyecto

El proyecto se parte en tres frentes que siguen las fases del caso: antes, durante y después del ataque. Cada frente tiene un dueño, pero los hallazgos y la defensa son de los tres.

	P1 · Durante	P2 · Antes	P3 · Después
Tema	Incidente, evidencia y simulación	Planeación, riesgos y controles	Terceros, IA, hallazgos y plan
Papel en el equipo	Analista técnico y custodio de evidencias	Coordinación e integración del informe	Revisión de calidad y cierre
Misiones del caso	C: forense, SQL Server, cronología, causa raíz	A, B y la parte de C sobre accesos, cambios, aplicaciones y móvil	D y E: terceros, privacidad, IA, hallazgos, plan y presupuesto
Alertas que prueba	08	01, 02, 03, 04, 09	05, 06, 07, 10, 11, 12

	P1 · Durante	P2 · Antes	P3 · Después
Evidencias que documenta	E-02, E-03, E-04, E-05, E-07	E-01, E-06	E-08, E-09, E-10
Contradicciones que resuelve	Administrador de BD, Seguridad Informática	Desarrollo	Gerencia de TI, Proveedor cloud, Comité de Auditoría, Continuidad
Preguntas del comité	01, 02, 03, 06, 07	09, 10	04, 05, 08
Carpetas a su cargo	03_Evidencias, 04_SQL y la presentación	01_Informe, 02_Matrices, 07_Referencias	05_Plan y el resumen ejecutivo
Rúbrica que más depende de su parte	Forense 2.5; comparte Controles de BD y Contención	Planeación 1.0, Riesgos 2.0, Controles 2.0	Terceros 1.5, Hallazgos 1.5, IA y seguimiento 1.5; comparte Contención

Los tres escriben su parte del informe, dos borradores de hallazgos y su propio registro de uso de IA. La defensa (1.5 puntos) es de todos, y cada uno responde por su frente.

Tus entregables

Entregas seis productos propios y armas los dos documentos que cierran el proyecto: el informe final y el anexo de referencias y uso de IA.

Entregable	Dónde queda	Qué lleva
Ficha de auditoría y carta de encargo	Secciones 1 y 2 del informe, y anexo	Objetivos, alcance, exclusiones, criterios, independencia, materialidad, cronograma, recursos y firmas simuladas

Entregable	Dónde queda	Qué lleva
Diagramas e inventario de activos	Sección 3 del informe y anexo	Arquitectura con fronteras de confianza, proceso comercial y tecnológico, activos críticos con dueño
Matriz de riesgos y programa de pruebas	02_Matrices/Matriz_Riesgos.xlsx	Escala, 12 o más riesgos con inherente y residual, Top 5, controles C-xx, pruebas T-xx de los tres y la tabla de las 12 alertas
Matriz RACI de RedNova	02_Matrices y anexo	Procesos críticos frente a roles, con los conflictos de funciones marcados
Papeles de trabajo PT-01 en adelante	Se los pasas a P1 para Papeles_Trabajo.pdf	E-01, E-06, bajas, MFA, cuentas compartidas, cambios y app móvil
Dos borradores de hallazgos	Se los pasas a P3 con la plantilla D	Accesos privilegiados y gestión de cambios, o app móvil si la prueba lo sostiene
Informe final	01_Informe/Informe_Final.pdf	Las secciones de los tres integradas, 12 a 18 páginas sin anexos
Referencias y declaración de IA	07_Referencias/Uso_IA.pdf	Bibliografía en APA 7 y los registros de uso de IA de los tres

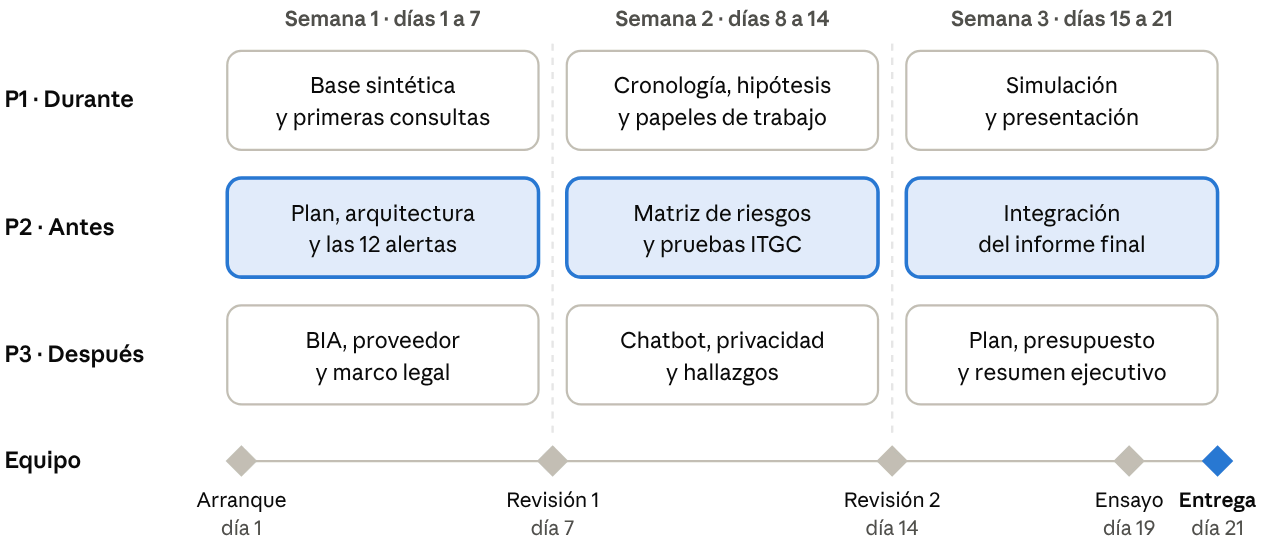
En la presentación te tocan tres diapositivas: encargo y alcance, de las alertas al Top 5, y controles evaluados.

Tu plan semana por semana

Contamos tres semanas desde la reunión de arranque (día 1) hasta la entrega (día 21). Si la fecha real cae antes, se comprimen las semanas, pero tu matriz tiene que estar el día 10 porque de ella dependen las pruebas y los hallazgos de los demás.

Cada semana cierra con una revisión; la entrega es el día 21

Tres frentes en paralelo, contados desde la reunión de arranque



plan del equipo · tu carril resaltado

Tu carril va resaltado. Las revisiones de los días 7 y 14 son donde se cruzan las entregas; como coordinador, tú convocas esas reuniones.

Semana 1 · días 1 a 7: plan, arquitectura y alertas

- [ ] Día 1: reunión de arranque. Recibir de P1 la plantilla UdeO y abrir el registro de supuestos S-xx.
- [ ] Días 1 a 3: ficha de auditoría y carta de encargo en borrador, con el nombre de la firma del equipo.
- [ ] Días 2 a 4: diagramas de arquitectura y de proceso, e inventario de activos críticos.
- [ ] Día 4: escala de riesgo (S-06) y tabla de las 12 alertas en borrador, para todos.
- [ ] Días 5 a 7: primera versión de la matriz (12 o más riesgos) y catálogo de controles C-xx.
- [ ] Día 6: recibir de P1 la base sintética y los resultados de Q-01 a Q-04 y Q-10.
- [ ] Día 7: revisión 1 con el equipo.

Semana 2 · días 8 a 14: matriz y pruebas

- [ ] Armar el programa de pruebas con las de los tres (P1 te pasa T-20 en adelante y P3, T-40 en adelante).
- [ ] Día 10: matriz v1 con Top 5 y programa de pruebas para todos.
- [ ] Ejecutar tus pruebas de ITGC con los resultados de P1: bajas, MFA, privilegios, cuentas compartidas y cambios. Diseñar la prueba de la app móvil.

- [ ] Escribir tus papeles PT-01 en adelante.
- [ ] Armar la matriz RACI de RedNova.
- [ ] Día 12: tus dos borradores de hallazgos a P3.
- [ ] Día 14: revisión 2. Revisas los borradores de P3 como si fueras el auditado.

Semana 3 · días 15 a 21: el informe

- [ ] Ajustar el riesgo residual con los resultados de las pruebas y el plan de P3.
- [ ] Día 15: esqueleto del informe en la plantilla UdeO, con las páginas de cada sección.
- [ ] Día 17: recibir las secciones, fuentes y registros de IA de P1 y P3; pasarle tus diapositivas a P1.
- [ ] Días 17 y 18: integrar el informe, unificar términos, numerar tablas y armar bibliografía y declaración de IA.
- [ ] Día 18: informe integrado a P3 para la revisión de calidad.
- [ ] Día 19: ensayo general.
- [ ] Día 20: correcciones y PDFs finales.
- [ ] Día 21: entrega.

Lo que recibes y lo que entregas

Tu matriz del día 10 es la referencia de todos: los R-xx y T-xx que fijes ahí son los que usan las consultas de P1 y el plan de P3.

Lo que entregas

Día	Qué	Para
1	Registro de supuestos abierto y carpeta del equipo revisada	Todos
4	Escala de riesgo (S-06) y tabla de las 12 alertas en borrador	P1 y P3
10	Matriz de riesgos v1, Top 5 y programa de pruebas con la numeración de todos	P1 y P3
12	Dos borradores de hallazgos	P3
14	Objeciones a los borradores de P3	P3

Día	Qué	Para
17	Tus tres diapositivas y tus papeles PT-01 en adelante	P1
18	Informe integrado, para revisión de calidad	P3
20	Informe final en PDF y 07_Referencias/Uso_IA.pdf	Todos

Lo que recibes

Día	Qué	De
1	Plantilla UdeO del informe	P1
4	BIA de referencia (S-05)	P3
6	Base sintética y resultados de Q-01 a Q-04 y Q-10	P1
8	Sus pruebas para el programa: T-20 en adelante y T-40 en adelante	P1 y P3
12	Borradores B3-1 y B3-2, para revisarlos el día 14	P3
14	Objeciones de P1 a tus borradores	P1
16	Plan de acción y presupuesto, para ajustar el residual	P3
17	Secciones del informe, fuentes y registros de uso de IA	P1 y P3
20	Índice de evidencias con hashes y Papeles_Trabajo.pdf, para los anexos	P1

Si algo se atrasa, avisa el mismo día en el grupo. Como coordinador, también eres quien recuerda las fechas a los demás.

Cómo armar el informe final

El informe tiene que caber en 12 a 18 páginas sin anexos y leerse como una sola voz. Apuntamos a 17 páginas para tener margen; si alguien se pasa, recorta en su sección y no en la de otro.

N.º	Sección	Escribe	Páginas
1	Carta de encargo y alcance	P2	1
2	Objetivos, criterios y metodología	P2	1
3	Entorno y arquitectura de RedNova	P2	1
4	Evaluación de riesgos y Top 5	P2	1.5
5	Controles ITGC, de aplicaciones y de base de datos	P2, con evidencia de P1	2
6	Análisis forense del incidente	P1	3
7	Respuesta, recuperación y continuidad	P1 y P3	1.5
8	Terceros, nube, privacidad, cumplimiento e IA	P3	2
9	Hallazgos	P3 consolida	2
10	Plan de acción y presupuesto	P3	1.5
11	Riesgo residual, limitaciones y conclusión	P2 y P3	0.5
	Total		17

Anexos (no cuentan en las páginas): A, matrices de riesgos, controles, pruebas y RACI; B, papeles de trabajo e índice de evidencias; C, base sintética y consultas SQL; D, cronología investigada; E, registro de supuestos; F, plan de acción y presupuesto detallados; G, bibliografía y declaración de uso de IA.

Pasos para integrarlo

1. Día 15: arma el esqueleto en la plantilla UdeO con estas secciones y compártelo.
2. Cada uno escribe en su sección, o te manda su .docx a más tardar el día 17.
3. Unifica términos (las palabras con significado fijo), códigos y formato. No cambies conclusiones de otros sin hablarlo.
4. Revisa que cada cifra del texto coincida con las matrices, el plan y los anexos.
5. Numera tablas y figuras, revisa las referencias cruzadas y arma la bibliografía.
6. Día 18: pásaselo a P3 para la revisión de calidad. Día 20: exporta el PDF final.

No hace falta que todos escriban igual. Sí hace falta que usen los mismos términos y que ninguna sección contradiga a otra.

La defensa de 12 minutos

La defensa abre con la simulación de P1 y tú entras justo después: tu parte explica por qué lo que pasó esa noche ya se veía venir. La dirige P1, que arma la estructura de diapositivas y lleva el cronómetro.

Minuto	Quién	Qué se muestra
0:00 a 2:00	P1	Corrida 1: la noche del 14 según los registros
2:00 a 5:30	P2	Encargo, alcance y criterios; de las 12 alertas a la matriz; Top 5; controles evaluados
5:30 a 8:00	P1	Cronología normalizada, hipótesis, qué está probado y qué no, causa raíz
8:00 a 11:00	P3	Proveedor, SLA y SOC 2; chatbot; hallazgos priorizados; plan y Q350,000
11:00 a 12:00	P3, con P1 operando	Corrida 2 con el plan funcionando; riesgo residual y decisiones que pedimos al comité

Tus tres diapositivas, unos 70 segundos cada una

1. Encargo y alcance: qué se auditó, qué se dejó fuera y con qué criterios. Una frase sobre independencia.
2. De las alertas al Top 5: cuántas alertas se volvieron riesgos, la matriz de calor y los cinco riesgos con su puntaje. El título dice la conclusión, no el tema.
3. Controles evaluados: qué se probó, con qué evidencia y qué resultó (cumple, no cumple, no concluyente).

Si el docente mete evidencia contradictoria sobre tu frente (por ejemplo, que el despliegue sí tenía aprobación escrita), di qué conclusión cambia, cuál se sostiene y qué pedirías para confirmarlo.

Convenciones del equipo

Se aprueban en la reunión de arranque y no se cambian sin avisar a los tres. Tú llevas el registro de supuestos, así que cualquier S-xx nuevo pasa por ti.

Códigos

Qué	Código	Quién numera
Riesgos y controles	R-01…, C-01…	P2
Pruebas y papeles de trabajo	T-01 a T-19 y PT-01 a PT-19	P2
Pruebas y papeles de trabajo	T-20 a T-39 y PT-20 a PT-39	P1
Pruebas y papeles de trabajo	T-40 a T-59 y PT-40 a PT-59	P3
Evidencias nuevas (E-01 a E-10 son del caso)	E-11 a E-29 / E-30 a E-39 / E-40 a E-49	P1 / P2 / P3; P1 lleva el índice de todas
Consultas SQL	Q-01 a Q-12	P1
Hallazgos	H-01… por prioridad; borradores B1-1, B2-1, B3-1…	P3
Acciones e indicadores del plan	A-01…, K-01…	P3
Supuestos del equipo	S-01…	P2 lleva el registro
Casos de prueba del chatbot	IA-01…	P3

Palabras con significado fijo

- Hecho confirmado: lo respalda evidencia suficiente y pertinente.
- Indicio: una señal que sugiere algo, pero no lo prueba.
- Hipótesis: una explicación posible, con evidencia a favor y en contra.
- Supuesto del equipo: algo que definimos porque el caso no lo dice; lleva código S-xx.
- No concluyente: lo disponible no alcanza para afirmar ni para descartar.

Nadie escribe "fuga" ni "exfiltración" como hecho mientras no esté probada. Se dice "transferencia de cerca de 1.6 GB hacia un destino externo no clasificado".

Supuestos que se aprueban al inicio

Código	Supuesto	Dueño	Listo el día
S-01	Nube, integraciones/API y soporte los presta un proveedor principal ("el Proveedor"), que usa subcontratistas	P3	1

Código	Supuesto	Dueño	Listo el día
S-02	Período revisado: controles del 1 de abril al 14 de octubre de 2026; incidente del 12 al 15 de octubre	P2	1
S-03	Hora de referencia: Guatemala (UTC−6), formato de 24 horas	P1	1
S-04	Horario de respaldos y fecha de la última restauración probada	P1	6
S-05	BIA de referencia: RTO, RPO y tiempo máximo tolerable por proceso	P3	4
S-06	Descriptores de probabilidad e impacto, escala de 1 a 5	P2	4
S-07	Tipo de cambio para costos en dólares, con la referencia del Banguat de una fecha fija	P3	15
S-08	Escala y umbral del puntaje de riesgo del chatbot (el 0.08 de E-10)	P3	8
S-09	Tamaño de la base sintética, por ejemplo 85,000 clientes ficticios	P1	3

Formato del informe

El de la plantilla UdeO que comparte P1: carta, márgenes de 1 pulgada, Times New Roman 12 justificado, interlineado 1.15, títulos de sección en 13 puntos negrita y tablas con el título "Tabla N." arriba. Citas y bibliografía en APA 7. Números con coma de miles y punto decimal: 31,840 registros, 1.6 GB, Q350,000.00.

Archivos

Una carpeta compartida con la estructura del curso, de 01_Informe a 07_Referencias. Nombres sin tildes ni espacios y con la versión al final, como Matriz_Riesgos_v2.xlsx. Cada quien edita sus archivos; para tocar el de otro, se avisa antes.

Cómo usar tu documento para el agente de IA

El documento para el agente trae el caso resumido, las convenciones, las reglas y diez tareas con lo que necesita para trabajar contigo. Úsalo así:

Tu documento para el agente: `Agente IA P2 — Planeación, riesgos y controles`

1. Abre una conversación nueva con el agente y pega el documento completo, o expórtalo a Markdown y adjúntalo. Adjunta también los dos PDFs del curso.
2. Pide una tarea a la vez ("Haz la Tarea 1") y revisa lo que entrega antes de pasar a la siguiente.
3. Trata lo que produzca como borrador: revisa cifras y fuentes, y asegúrate de entender cada riesgo, cada puntaje y cada prueba.
4. Al cerrar cada sesión, pídele la entrada del registro de uso de IA. La validación y lo que aprendiste los completas tú, no el agente.
5. Si inventa algo (una norma, una versión, un control que no existe), corrígelo y anótalo en el registro; eso también cuenta como validación.

Como vas a armar la declaración de uso de IA del equipo, recuérdales a P1 y P3 que lleven su registro desde el primer día.

Lo que debes poder explicar sin leer

En la defensa preguntan a cada integrante por separado. Si puedes explicar cada punto con tus palabras y un dato del caso, estás listo.

1. Por qué el alcance y las exclusiones son esos, y qué significa materialidad en una auditoría de TI.
2. La diferencia entre riesgo, vulnerabilidad, falla de control, indicio y hallazgo, con un ejemplo del caso como la alerta 03.
3. Cómo se calculó cada riesgo del Top 5 y por qué quedó en ese orden.
4. Riesgo inherente frente a residual, y cómo se evaluaron el diseño y la operación de cada control.
5. Qué es un ITGC y cuáles se probaron.
6. Por qué una aprobación verbal no es evidencia suficiente (la contradicción de Desarrollo).
7. Cómo se prueba que una corrección funciona más allá de instalarla (pregunta 09): que esté bien diseñada, que opere durante un período y que la consulta que detectó la falla ya no la encuentre.
8. Qué riesgo residual tiene que aceptar la gerencia y quién debe firmar esa aceptación (pregunta 10).
9. Qué muestra la matriz RACI y dónde hay conflictos de funciones, por ejemplo administradores que pueden alterar la bitácora.

10. Por qué la prueba de la app móvil se hizo en laboratorio, y qué demuestra y qué no sobre la app real de RedNova.

Revisión final antes de entregar

Marca cada punto el día 20, antes de exportar los PDFs.

- [ ] La ficha tiene objetivo general, al menos cuatro objetivos específicos, alcance, exclusiones, limitaciones, criterios y cronograma.
- [ ] La matriz tiene 12 o más riesgos, escala documentada, inherente, efectividad del control y residual, y el Top 5 está justificado.
- [ ] Ninguna alerta quedó copiada como si fuera un hallazgo.
- [ ] Cada control significativo se vincula con su prueba, su criterio y su evidencia.
- [ ] El programa de pruebas incluye las de los tres, sin números repetidos.
- [ ] El informe tiene entre 12 y 18 páginas sin anexos y sus cifras coinciden con las matrices y los anexos.
- [ ] La bibliografía está en APA 7 con la versión de cada marco, y la declaración de IA trae los registros de los tres.
- [ ] P3 hizo la revisión cruzada de ortografía, sumas, códigos y fechas, y tus correcciones ya están aplicadas.
- [ ] Tu registro de uso de IA está completo.